

SAE4 Cyber : Annexe

Khawla BENSGHIR

Clément HERBRECHT-BOURGOIN

Bohdan DYSHLEVYY

Faysa NJIMI

Adrien ROMANO

Mael PIRAT

Contenu

Collecte d'informations (Reconnaissance passive et active)....	3
Scan réseau et fingerprinting.....	29
Scan de vulnérabilités Web.....	37
Tests d'injection et d'exploitation Web.....	50
Tests d'exploitabilité applicative.....	60
Mode avancé & automatisation.....	69
Fonctionnement du Scoring Harmonisé (BACKEND).....	71

Collecte d'informations (Reconnaissance passive et active)

theHarvester : un outil OSINT de reconnaissance

Description :

theHarvester est un outil OSINT (Open Source Intelligence) utilisé pour la reconnaissance passive. Il permet de collecter un grand nombre d'informations sur une cible à partir de sources publiques.

Cet outil est particulièrement utile pour déterminer le périmètre d'une entreprise avant une phase de test d'intrusion ou un audit de sécurité. Il est préinstallé dans Kali Linux.

Informations récupérées par theHarvester :

- Adresses e-mail
- Sous-domaines
- Adresses IP
- URLs

Syntaxe de base :

```
theHarvester -d [domaine] -l [profondeur] -b [moteur] -f [fichier]
```

Exemple d'utilisation :

Cet exemple collecte jusqu'à 600 résultats à partir de LinkedIn pour le domaine entreprise.com et enregistre les résultats dans un fichier HTML nommé results.html

```
(kali@kali)-[~]
$ theHarvester -d [redacted] -l 600 -b linkedin -f results.html
```

Barre verticale

theHarvester

theHarvester 4.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com

Expressions rationnelles

*] Target: docaposte

Searching 100 results.
Searching 200 results.
Searching 300 results.
Searching 400 results.
Searching 500 results.
Searching 600 results.

*] Searching LinkedIn.

*] LinkedIn Users found: 86

ARNAUD [redacted] - Directeur de programmes
Abdelmoumen [redacted]
Ahmed [redacted]
Alexandre [redacted]

Pourquoi avons-nous utilisé theHarvester pour notre phase OSINT ?

Dans le cadre de la phase de reconnaissance passive de notre audit, nous avons choisi d'utiliser theHarvester car c'est un outil simple, rapide et efficace pour collecter automatiquement des informations accessibles publiquement sur une cible.

Contrairement à d'autres outils plus complexes ou trop spécialisés, theHarvester nous a permis de :

- Centraliser les résultats provenant de plusieurs sources (Bing, Google, LinkedIn, etc.)

- Automatiser la collecte d'e-mails, sous-domaines, IPs et URLs sans faire de recherches manuelles
 - Exporter facilement les résultats dans un fichier HTML pour les analyser et les documenter dans notre rapport
-
-

Moteur : Bing

Description :

Bing est un moteur de recherche développé par Microsoft. Bien qu'il soit souvent comparé à Google, il possède son propre algorithme et sa propre base de données, ce qui peut entraîner des résultats différents et parfois plus pertinents dans certains contextes.

Pourquoi l'utiliser ?

- Bing est particulièrement utile pour la collecte d'informations en raison de ses capacités d'indexation distinctes. Il permet notamment de :
 - Récupérer des adresses e-mail associées à un domaine cible.
- Trouver des sous-domaines liés à un site web.
- Explorer des pages web indexées qui peuvent ne pas apparaître sur Google.
- Contourner certaines restrictions ou filtres mis en place par d'autres moteurs de recherche.

Utilisation typique :

Bing est une alternative efficace lorsque Google limite l'accès à certaines informations ou applique des filtres de confidentialité et de sécurité. Dans le cadre d'un audit OSINT (Open Source Intelligence), Bing peut offrir des résultats complémentaires et améliorer la diversité des données collectées.

Exemple de commande :

```
theHarvester -d exemple.com -b bing
```

Cette commande permet d'exploiter Bing pour récupérer les informations publiques liées à un domaine spécifique.

Outils : Whois

Description :

Whois est un outil open-source intégré par défaut sur la plupart des systèmes Linux et Unix. Il permet d'interroger les bases de données des registres de noms de domaine (ICANN, RIPE, ARIN, APNIC, etc.) pour récupérer des informations administratives et techniques sur un domaine.

Pourquoi utiliser Whois dans un audit ?

- Whois est un outil clé en OSINT (Open Source Intelligence) et en reconnaissance passive, permettant de :
 - Collecter des informations sur un nom de domaine : propriétaire, e-mail de contact, hébergeur, date de création/expiration, etc.
- Réaliser une reconnaissance passive, sans générer de trafic vers la cible.
- Identifier d'éventuelles fuites d'informations sensibles (ex : e-mails personnels ou adresses physiques visibles dans les enregistrements publics).

Pourquoi Whois est considéré comme un outil de reconnaissance passive ?

Whois a été intégré dans notre algorithme à la suite de TheHarvester afin de compléter la phase de reconnaissance passive avec des informations administratives précises sur la cible, sans jamais interagir directement avec elle.

- Pas d'envoi de paquets au domaine cible : aucune requête n'est envoyée à l'infrastructure de l'entreprise analysée.
- Aucune alerte déclenchée : un IDS/IPS (système de détection d'intrusion) ne peut pas détecter son utilisation, car il ne touche pas le réseau de la cible.

Utilisation typique en terminal :

[whois google.com](#)

Outils : Dig

Description :

Dig (Domain Information Groper) est un outil puissant permettant d'interroger les serveurs DNS pour obtenir des informations détaillées sur un domaine. Contrairement à Whois, Dig permet d'examiner les enregistrements DNS d'un domaine en temps réel.

Pourquoi utiliser Dig dans un audit ?

- Dig est particulièrement utile pour :
Récupérer des informations DNS : adresse IP d'un domaine, serveurs de noms (NS), enregistrements MX (mails), TXT, etc.
- Analyser la configuration DNS d'une entreprise et repérer des erreurs de configuration.
- Identifier d'éventuelles fuites d'informations via des enregistrements DNS mal protégés.

Exemple de commandes Dig :

- Récupérer l'adresse IP d'un domaine :

`dig google.com`

- Lister les serveurs de noms associés à un domaine :

`dig NS google.com`

- Afficher tous les enregistrements disponibles :

`dig ANY google.com`

Whois vs Dig – Quelle différence ?

Outil	Type d'information collectée	Interaction avec la cible	Utilisation principale
Whois	Données administratives et d'enregistrement d'un domaine	Aucune (base de données publique)	OSINT, collecte d'infos sur un propriétaire de domaine
Dig	Informations DNS en temps réel	Requête envoyée aux serveurs DNS	Audit réseau, détection de fuites via DNS

Grâce à leur complémentarité, Whois et Dig sont des outils essentiels pour tout analyste en cybersécurité ou en pentesting.

Exemple d'utilisation :

google.com

Updated 5 hours ago

Domain Information	
Domain:	google.com
Registered On:	1997-09-15
Expires On:	2028-09-14
Updated On:	2019-09-09
Status:	client delete prohibited client transfer prohibited client update prohibited server delete prohibited server transfer prohibited server update prohibited
Name Servers:	ns1.google.com ns2.google.com ns3.google.com ns4.google.com

Registrar Information	
Registrar:	MarkMonitor Inc.

Sale

.space

~~\$29.88~~
\$1.18

BUY NOW

*while stocks last

On Sale!

.online

.ONLINE @ \$1.58 ~~\$39.88~~

Introducing

WORDPRESS HOSTING

Informations affichées par défaut :

- En l'absence d'options spécifiques, la commande dig google.com retourne :
- Adresse IP du serveur (A record) : Correspond à l'adresse IPv4 associée à google.com.
- Serveur DNS interrogé : Indique le serveur ayant répondu à la requête.
- Temps de réponse : Durée nécessaire pour obtenir les résultats.
- Enregistrements DNS retournés : Liste des enregistrements DNS obtenus.

```
plaintext Copier Modifier

; <<>> DiG 9.16.1 <<>> google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 26377
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; QUESTION SECTION:
google.com.                IN      A

;; ANSWER SECTION:
google.com.                300     IN      A      142.250.191.14

;; Query time: 12 msec
;; SERVER: 8.8.8.8#53(8.8.8.8)
;; WHEN: Mon Feb 18 14:32:56 UTC 2025
;; MSG SIZE rcvd: 55
```

Description Amass

Amass est un outil avancé d'énumération de sous-domaines développé par l'OWASP. Contrairement à Sublist3r, Amass adopte une approche plus approfondie et complète, combinant OSINT, bruteforce et reconnaissance active.

Fonctionnalités principales :

- Collecte d'informations via OSINT, analyse passive, et requêtes actives DNS.
- Recherche avancée à partir de base de données publiques, API, et historiques DNS.
- Support du bruteforce avancé, avec des wordlists personnalisées.
- Utilisation de graphes relationnels pour visualiser l'infrastructure d'un domaine.
- Génération de rapports détaillés pour une analyse approfondie.

Exemple d'utilisation d'Amass

- Énumération passive des sous-domaines :

`amass enum -passive -d example.com`

- Énumération active avec requêtes DNS :

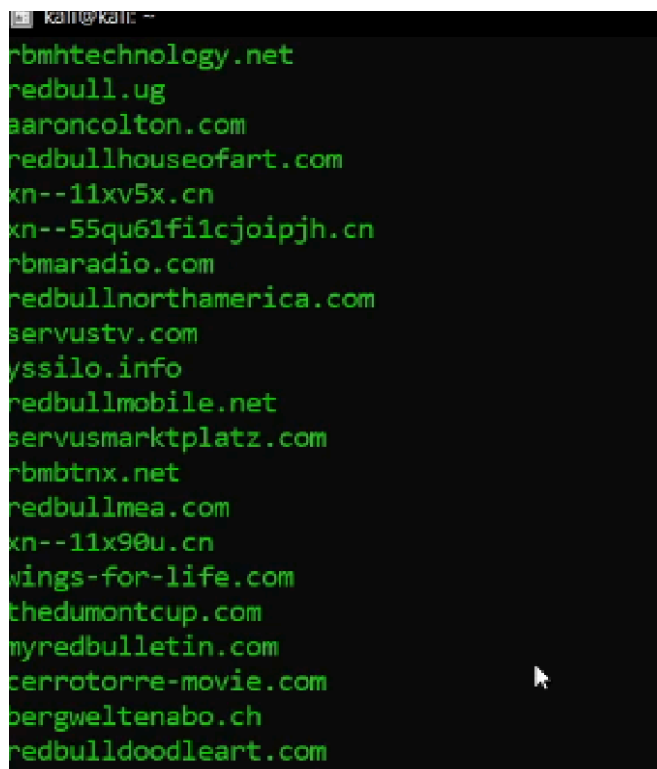
`amass enum -active -d example.com`

- Bruteforce avec une wordlist personnalisée :

`amass enum -brute -w /chemin/vers/wordlist.txt -d example.com`

Pourquoi utiliser Amass ?

- Approche plus complète et approfondie que Sublist3r.
- Permet d'identifier des sous-domaines cachés, y compris ceux non indexés.
- Intègre plusieurs sources d'information (moteurs de recherche, bases de données, historiques DNS, etc.).
- Idéal pour des audits de sécurité avancés et des tests approfondis sur une cible.



```
kali@kali: ~$ amass enum -active -d example.com
rbmhtechology.net
redbull.ug
aaroncolton.com
redbullhouseofart.com
xn--11xv5x.cn
xn--55qu61fi1cjoipjh.cn
rbmaradio.com
redbullnorthamerica.com
servustv.com
yssilo.info
redbullmobile.net
servusmarktplatz.com
rbmbtnx.net
redbullmea.com
xn--11x90u.cn
wings-for-life.com
thedumontcup.com
myredbulletin.com
terrotorre-movie.com
bergweltenabo.ch
redbulldoodleart.com
```

- Génération de **graphiques** pour illustrer les connexions entre les actifs.
- **Intégration avec d'autres outils** comme Gobuster ou Maltego.

Pourquoi avons-nous utilisé Amass dans notre audit ?

Nous avons choisi **Amass** car il va **plus loin que les outils basiques comme Sublist3r ou theHarvester**.

Notre objectif était d'avoir une **vision complète et structurée de l'infrastructure externe de la cible**, notamment en découvrant :

- des **sous-domaines cachés** ou oubliés,
- des **infrastructures exposées** (ex : API, serveurs de test, VPN...),
- et les **liens entre les différents services et IPs**.

Amass nous a permis de :

1. **Recueillir des données à partir de multiples sources OSINT**, comme les certificats SSL, les archives web ou les bases DNS.
2. **Utiliser le mode bruteforce** avec une wordlist DNS personnalisée pour découvrir des sous-domaines non référencés.
3. **Visualiser les résultats sous forme de graphe**, ce qui nous a aidé à identifier les zones critiques.
4. **Compléter et valider les résultats obtenus avec theHarvester**, en découvrant des actifs que ces outils n'avaient pas détectés.

Sublist3r vs Amass – Quelle différence ?

Outil	Type d'énumération	Rapidité	Approche	Utilisation recommandée
Sublist3r	OSINT via moteurs de recherche + Bruteforce DNS	Rapide	Reconnaissance passive	Audit rapide, tests ponctuels
Amass	OSINT + Bruteforce DNS + Requêtes actives	Plus lent	Analyse complète et approfondie	Audit avancé, tests d'intrusion complexes

Sublist3r est idéal pour une reconnaissance rapide, tandis qu'Amass est plus puissant pour une analyse approfondie et complète d'un domaine cible. Utiliser les deux en complément peut offrir une vision plus détaillée de l'infrastructure DNS.

Outils : AutoRecon & Recon-ng

AutoRecon – Scanner Automatisé pour la Reconnaissance

Description AutoRecon :

AutoRecon est un outil de reconnaissance automatisé conçu pour simplifier la collecte d'informations sur une cible. Il est principalement utilisé lors des tests d'intrusion et des audits de sécurité. Contrairement aux scanners classiques, AutoRecon effectue une reconnaissance

passive et active en exécutant divers outils en parallèle, tout en organisant les résultats pour une analyse efficace.

Fonctionnalités principales :

- Exécution automatisée d'outils comme Nmap, WhatWeb, Nikto, Gobuster, etc.
- Scan intelligent : commence par des scans rapides, puis approfondit selon les résultats.
- Génération de rapports structurés, facilitant l'exploitation des données collectées.
- Multithreading pour une exécution rapide et optimisée.
- Compatible avec Kali Linux et d'autres distributions de pentesting.

Exemple d'utilisation d'AutoRecon

- Lancer un scan de base sur un domaine ou une IP :

```
autorecon -t example.com
```

- Lancer un scan avec des options avancées :

```
autorecon -t example.com --only-scans full
```

Pourquoi utiliser AutoRecon ?

- Gagne du temps en automatisant la reconnaissance initiale.
- Idéal pour les phases de reconnaissance en test d'intrusion.
- Organisation claire des résultats, facilitant leur analyse.

Recon-ng – Un Framework OSINT Puissant

Description Recon-ng :

Recon-ng est un framework OSINT modulaire permettant la collecte avancée d'informations sur une cible. Il s'inspire de Metasploit et est

conçu pour être extensible grâce à ses nombreux modules. Recon-ng ne se contente pas d'afficher les résultats dans le terminal : il les stocke également dans une base de données, ce qui permet d'alimenter les résultats d'un module dans un autre pour une collecte d'informations plus poussée.

Fonctionnalités principales :

- Framework modulaire avec de nombreux modules OSINT intégrés.
- Stockage des résultats dans une base de données, facilitant le croisement d'informations.
- Automatisation possible, avec des scripts personnalisés.
- Intégré par défaut dans Kali Linux.

Utilisation de Recon-ng pour analyser un domaine :

- Démarrer l'interface de Recon-ng :

recon-ng

- Ajouter un workspace spécifique à la cible :

workspaces create tesla

- Utiliser un module pour récupérer des sous-domaines :

modules load recon/domains-hosts/hackertarget

set source tesla.com

run

Pourquoi utiliser Recon-ng ?

- Idéal pour la collecte d'informations OSINT sur le Web.
- Puissant grâce à son architecture modulaire et l'interconnexion des modules.
- Garde une trace des résultats dans une base de données pour une meilleure exploitation.

Exemple de comment marche reco-ng :

Utilisons recon-ng pour compiler des données intéressantes sur tesla
Pour commencer, exécutons simplement recon ng

```
recon-ng
[*] Version check disabled.

Sponsored by ...

BLACK HILLS
www.blackhillsinfosec.com

PRACTISEC
www.practisec.com

[recon-ng v5.1.1, Tim Tomes (@lanmaster53)]

[*] No modules enabled/installed.

[recon-ng][default] >
```

Selon sa description, ce module recherche sur Google avec l'opérateur "
et il ne nécessite pas de clé API Installons le module avec marketplace
install

```
[recon-ng][default] > marketplace info recon/domains-hosts/google_site_web

+-----+
| path      | recon/domains-hosts/google_site_web |
| name      | Google Hostname Enumerator           |
| author     | Tim Tomes (@lanmaster53)             |
| version    | 1.0                                   |
| last_updated | 2019-06-24                           |
| description | Harvests hosts from Google.com by using the 'site' search operator. Updates the 'hosts' table with the results. |
| required_keys | []                                     |
| dependencies | []                                     |
| files      | []                                     |
| status     | not installed                         |
+-----+

[recon-ng][default] >
```

```
[recon-ng][default] > marketplace install recon/domains-hosts/google_site_web
[*] Module installed: recon/domains-hosts/google_site_web
[*] Reloading modules ...
[recon-ng][default] >
```

Après avoir installé le module, nous pouvons le charger avec module
load suivi de son nom Ensuite, nous utiliserons les informations pour
afficher les détails sur le module et les paramètres requis

```
[recon-ng][default] > modules load recon/domains-hosts/google_site_web
[recon-ng][default][google_site_web] > info

Name: Google Hostname Enumerator
Author: Tim Tomes (@lanmaster53)
Version: 1.0

Description:
Harvests hosts from Google.com by using the 'site' search operator. Updates the 'hosts' table with the results.

Options:


| Name   | Current Value | Required | Description                              |
|--------|---------------|----------|------------------------------------------|
| SOURCE | default       | yes      | source of input (see 'info' for details) |



Source Options:
default      SELECT DISTINCT domain FROM domains WHERE domain IS NOT NULL
<string>     string representing a single input
<path>       path to a file containing a list of inputs
query <sql>  database query returning one column of inputs

[recon-ng][default][google_site_web] > █
```

Notez que la sortie contient des informations supplémentaires sur le module maintenant que nous l'avons installé et chargé. Selon la sortie, le module nécessite

l'utilisation d'une source, qui est la cible sur laquelle nous voulons collecter des informations. Dans ce cas, nous utiliserons les options `set SOURCE tesla.com` pour

définir notre domaine cible

```
[recon-ng][default][google_site_web] > options set SOURCE tesla.com
SOURCE => tesla.com
[recon-ng][default][google_site_web] > █
```

Enfin nous lançons le module avec `run`

```
[recon-ng][default][google_site_web] > run

TESLA.COM

[*] Searching Google for: site:tesla.com
[!] Google CAPTCHA triggered. No bypass available.
```

La requête a été bloquée par un CAPTCHA google. Un pentester doit toujours trouver une autre solution en cas de blocage. Utilisons un autre module en suivant les mêmes étapes.

Nous allons utiliser un autre module hackertarget qui nous permettra d'avoir les mêmes informations en suivant les même étapes info, install load run

```
[recon-ng][default][hackertarget] > run

TESLA.COM

[*] Country: None
[*] Host: tesla.com
[*] Ip_Address: 96.16.108.43
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*]
[*] Country: None
[*] Host: o7.ptr6980.tesla.com
[*] Ip_Address: 149.72.144.42
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*]
[*] Country: None
[*] Host: vpn1.tesla.com
[*] Ip_Address: 8.45.124.215
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*]
[*] Country: None
[*] Host: apacvpn1.tesla.com
[*] Ip_Address: 8.244.131.215
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
```

Nous pouvons utiliser la commande show hosts pour afficher les données stockées

```
[recon-ng][default][hackertarget] > back
[recon-ng][default] > show hosts
```

rowid	host	ip_address	region	country	latitude	longitude	notes	module
1	fs1.megacorpone.com	51.222.169.210						hackertarget
2	ns1.megacorpone.com	51.79.37.18						hackertarget
3	mail2.megacorpone.com	51.222.169.213						hackertarget
4	ns2.megacorpone.com	51.222.39.63						hackertarget
5	www2.megacorpone.com	149.56.244.87						hackertarget
6	ns3.megacorpone.com	66.70.207.180						hackertarget
7	beta.megacorpone.com	51.222.169.209						hackertarget
8	syslog.megacorpone.com	51.222.169.217						hackertarget
9	mail.megacorpone.com	51.222.169.212						hackertarget
10	siem.megacorpone.com	51.222.169.215						hackertarget
11	admin.megacorpone.com	51.222.169.208						hackertarget
12	vpn.megacorpone.com	51.222.169.220						hackertarget
13	snmp.megacorpone.com	51.222.169.216						hackertarget
14	router.megacorpone.com	51.222.169.214						hackertarget
15	intranet.megacorpone.com	51.222.169.211						hackertarget
16	support.megacorpone.com	51.222.169.218						hackertarget
17	test.megacorpone.com	51.222.169.219						hackertarget
18	www.megacorpone.com	149.56.244.87						hackertarget
19	tesla.com	96.16.108.43						hackertarget
20	o7.ptr6980.tesla.com	149.72.144.42						hackertarget
21	vpn1.tesla.com	8.45.124.215						hackertarget
22	apacvpn1.tesla.com	8.244.131.215						hackertarget
23	cnvpn1.tesla.com	114.141.176.215						hackertarget
24	vpn2.tesla.com	8.47.24.215						hackertarget
25	model3.tesla.com	205.234.27.221						hackertarget
26	o3.ptr1444.tesla.com	149.72.152.236						hackertarget
27	o2.ptr556.tesla.com	149.72.134.64						hackertarget
28	o5.ptr8466.tesla.com	149.72.172.170						hackertarget
29	o6.ptr9437.tesla.com	168.245.123.10						hackertarget
30	o4.ptr1867.tesla.com	149.72.163.58						hackertarget
31	marketing.tesla.com	13.111.47.196						hackertarget
32	o1.ptr2410.link.tesla.com	149.72.247.52						hackertarget
33	referral.tesla.com	72.10.32.90						hackertarget

Examinons un autre module recon /hosts hosts/ resolve qui nous permettra de résoudre des noms de hôtes avec des IPs avec marketplace info

```
[recon-ng][default] > marketplace info recon/hosts-hosts/resolve
```

path	recon/hosts-hosts/resolve
name	Hostname Resolver
author	Tim Tomes (@lanmaster53)
version	1.0
last_updated	2019-06-24
description	Resolves the IP address for a host. Updates the 'hosts' table with the results.
required_keys	[]
dependencies	[]
files	[]
status	not installed

```
[recon-ng][default] > █
```

Une fois le module installé, nous pouvons l'utiliser avec modules load run et info pour afficher des informations sur le module et ses options

```

[recon-ng][default] > marketplace install recon/hosts-hosts/resolve
[*] Module installed: recon/hosts-hosts/resolve
[*] Reloading modules ...
[recon-ng][default] > modules load recon/hosts-hosts/resolve
[recon-ng][default][resolve] > info

    Name: Hostname Resolver
    Author: Tim Tomes (@lanmaster53)
    Version: 1.0

Description:
    Resolves the IP address for a host. Updates the 'hosts' table with the results.

Options:


| Name   | Current Value | Required | Description                              |
|--------|---------------|----------|------------------------------------------|
| SOURCE | default       | yes      | source of input (see 'info' for details) |



Source Options:
default      SELECT DISTINCT host FROM hosts WHERE host IS NOT NULL AND ip_address IS NULL
<string>     string representing a single input
<path>       path to a file containing a list of inputs
query <sql>   database query returning one column of inputs

Comments:
    * Note: Nameserver must be in IP form.

[recon-ng][default][resolve] > █

```

Comme il ressort clairement de la sortie précédente, ce module résoudra l'adresse IP d'un hôte. Nous devons fournir l'adresse IP que nous voulons résoudre comme source. Nous avons quatre options que nous pouvons définir pour la source : default, string, path et query. Chaque option est accompagnée d'une description, comme indiqué. Par exemple, dans le module de reconnaissance « google_site_web », nous avons utilisé une valeur de chaîne.

Nous allons choisir de résoudre tesla.com

```
[recon-ng][default][resolve] > options set SOURCE tesla.com
SOURCE => tesla.com
[recon-ng][default][resolve] > run
[*] tesla.com => 23.9.66.10
[*] tesla.com => 184.50.204.169
[*] tesla.com => 184.85.228.70
[*] tesla.com => 23.201.26.71
[*] tesla.com => 104.119.104.74
[*] tesla.com => 96.16.108.43
[*] tesla.com => 184.30.18.203

SUMMARY

[*] 6 total (6 new) hosts found.
[recon-ng][default][resolve] > █
```

Nous avons maintenant des adresses IP

resolvant tesla.com Si nous affichons à nouveau les hôtes, nous pouvons vérifier

que la base de données a été mise à jour avec les résultats des deux modules

54	tesla.com	184.50.204.169						resolve
55	tesla.com	184.85.228.70						resolve
56	tesla.com	23.201.26.71						resolve
57	tesla.com	104.119.104.74						resolve
58	tesla.com	96.16.108.43						resolve
59	tesla.com	184.30.18.203						resolve

AutoRecon vs Recon-ng – Quelle différence ?

Outil	Type de reconnaissance	Approche	Utilisation principale
AutoRecon	Reconnaissance automatique (passive & active)	Exécute plusieurs outils en parallèle	Automatiser la phase de reconnaissance en pentesting

Recon-ng	OSINT et collecte d'informations Web	Framework modulaire avec base de données	Analyse avancée et croisement des données OSINT
----------	--------------------------------------	--	---

AutoRecon est parfait pour une reconnaissance rapide et automatisée, tandis que Recon-ng permet une analyse approfondie en OSINT. Les deux peuvent être utilisés de manière complémentaire pour maximiser la collecte d'informations !

SpiderFoot, Un Outil OSINT de Reconnaissance

Description SpiderFoot ?

SpiderFoot est un outil OSINT (Open Source Intelligence) de reconnaissance automatique qui collecte des informations à partir de plus de 100 sources de données publiques. Il est particulièrement utile en pentesting, audit de sécurité, enquête numérique et surveillance. Grâce à son approche modulaire, il permet de cartographier les liens entre diverses entités comme les adresses IP, domaines, e-mails, noms, réseaux sociaux, bases de données compromises, etc.

Fonctionnalités principales

- Analyse automatisée à partir d'une large gamme de sources OSINT (Shodan, VirusTotal, HavelBeenPwned, etc.).
- Collecte d'informations sur plusieurs types d'entités :
 - Adresses IP

- Noms de domaine et sous-domaines
- Adresses e-mail
- Informations WHOIS et DNS
- Fuites de données
- Réseaux sociaux et forums
- Interface Web interactive avec visualisation des relations entre les entités.
- Mode ligne de commande pour les audits automatisés.
- Exportation des résultats sous différents formats pour une analyse approfondie.

Exemple d'utilisation de SpiderFoot

- Lancer un scan basique via l'interface Web

`spiderfoot -l 127.0.0.1:5001`

Puis accéder à l'interface via <http://127.0.0.1:5001> et configurer l'analyse.

- Lancer une analyse en ligne de commande sur un domaine cible :

`spiderfoot -m all -t example.com`

- Exporter les résultats en fichier JSON pour une analyse ultérieure

`spiderfoot -m all -t example.com --json-output resultats.json`

Pourquoi utiliser SpiderFoot ?

- Idéal pour une reconnaissance approfondie et automatisée.
- Récupérer des informations précieuses sur une cible en un seul scan.
- Interface Web intuitive pour visualiser les liens entre les données collectées.
- Puissant en complément d'autres outils OSINT comme Recon-ng ou theHarvester.

SpiderFoot vs Autres Outils OSINT

Outil	Type d'analyse	Sources de données	Interface	Utilisation principale
SpiderFoot	OSINT automatisé	+100 sources (Shodan, HavelBeenPwned, etc.)	Web & CLI	Reconnaissance avancée, cartographie des relations
Recon-ng	OSINT modulaire	Principalement Web et réseaux sociaux	CLI avec base de données	Collecte structurée et interconnexion des résultats
theHarvester	OSINT rapide	Moteurs de recherche & bases publiques	CLI	Récupération rapide d'e-mails, sous-domaines et IPs

SpiderFoot est un outil puissant pour automatiser la collecte d'informations et identifier les liens cachés entre les entités d'une cible. Il est particulièrement utile pour les analystes en cybersécurité, les enquêteurs numériques et les experts en OSINT. 🚀

Exemple :

-SpiderFoot est préinstallée dans les nouvelles versions de Kali Linux.

```

$ spiderfoot --help
usage: sf.py [-h] [-d] [-l IP:port] [-m mod1,mod2,...] [-M] [-s TARGET] [-t type1,type2,...] [-T] [-o tab|csv|json] [-u] [-n] [-e] [-S LENGTH] [-D DELIMITER] [-f] [-F type1,type2,...] [-x] [-q] [-V]

SpiderFoot 3.5.0: Open Source Intelligence Automation.

optional arguments:
  -h, --help            show this help message and exit
  -d, --debug           Enable debug output.
  -l IP:port            IP and port to listen on.
  -m mod1,mod2,...     Modules to enable.
  -M, --modules         List available modules.
  -s TARGET             Target for the scan.
  -t type1,type2,...   Event types to collect (modules selected automatically).
  -T, --types           List available event types.
  -o tab|csv|json       Output format. Tab is default.
  -u                    Don't print field headers, just data.
  -n                    Strip newlines from data.
  -e                    Include the source data field in tab/csv output.
  -S LENGTH             Maximum data length to display. By default, all data is shown.
  -D DELIMITER          Delimiter to use for CSV output. Default is ','.
  -f                    Filter out other event types that weren't requested with -t.
  -F type1,type2,...   Show only a set of event types, comma-separated.
  -x                    STRICT MODE. Will only enable modules that can directly consume your target, and if -t was specified only those events will be consumed by modules. This overrides -t and -m options.
  -q                    Disable logging. This will also hide errors!
  -V, --version         Display the version of SpiderFoot and exit.
kali@kali:~$

```

SpiderFoot est utilisé à travers une interface web. Pour cela, nous lançons un serveur web en local sur le port 5151 : SpiderFoot l 127.0.0.1:5151 et nous visitons la l'url <http://127.0.0.1:5151>

```

(kali@kali)-[~]
└─$ spiderfoot -l 127.0.0.1:5151
2022-08-17 11:45:13,634 [INFO] sf : Starting web server at 127.0.0.1:5151 ...

*****
Use SpiderFoot by starting your web browser of choice and
browse to http://127.0.0.1:5151/
*****

2022-08-17 11:45:13,651 [WARNING] sf :
*****
Warning: passwd file contains no passwords. Authentication disabled.
Please consider adding authentication to protect this instance!
Refer to https://www.spiderfoot.net/documentation/#security.
*****

```

Scan réseau et fingerprinting

Outils : Nmap

Description de l'outil :

Nmap (Network Mapper) est un outil open-source puissant utilisé pour l'exploration et l'analyse des réseaux. Il permet de détecter les hôtes actifs, d'identifier les ports ouverts, de déterminer les services en écoute, et d'effectuer du fingerprinting des systèmes d'exploitation et des applications réseau.

Nmap offre plusieurs modes de scan, notamment :

- **Scan SYN (-sS)** : Permet de scanner les ports sans établir de connexion complète.
- **Scan complet (-sT)** : Établit une connexion complète avec chaque port ouvert détecté.
- **Détection du système d'exploitation (-O)** : Tente d'identifier le système d'exploitation de la cible.
- **Scan de versions des services (-sV)** : Permet d'obtenir des informations détaillées sur les services en écoute.

Pourquoi on l'a utilisé :

Nous avons utilisé Nmap pour :

- Identifier les machines actives sur le réseau cible.
- Découvrir les services et ports ouverts.

- Obtenir des informations sur les versions des logiciels et les systèmes d'exploitation.
- Rechercher d'éventuelles vulnérabilités en fonction des services détectés.

Exemple d'utilisation :

```
nmap -sS -p- -O -sV 192.168.1.0/24
```

Ce scan détecte tous les hôtes actifs sur le réseau 192.168.1.0/24, identifie les ports ouverts, les services actifs ainsi que leurs versions, et tente de déterminer le système d'exploitation utilisé.

Captures d'écran :

```

[redacted]@[redacted]:~/Desktop$ nmap -T4 192.168.0.239
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-28 06:19 CST
Nmap scan report for 192.168.0.239
Host is up (0.0016s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 11.11 seconds
[redacted]@[redacted]:~/Desktop$
```

Outil : WhatWeb

Description de l'outil :

WhatWeb est un outil de reconnaissance web permettant d'identifier les technologies utilisées par un site web. Il détecte automatiquement les CMS, les frameworks, les serveurs web, ainsi que d'autres composants d'un site.

Cet outil peut révéler des informations comme :

- Le type et la version du CMS utilisé (WordPress, Joomla, etc.).
- Le serveur web et sa version (Apache, Nginx, etc.).
- Les bibliothèques JavaScript utilisées.

Pourquoi on l'a utilisé :

Nous avons utilisé WhatWeb pour :

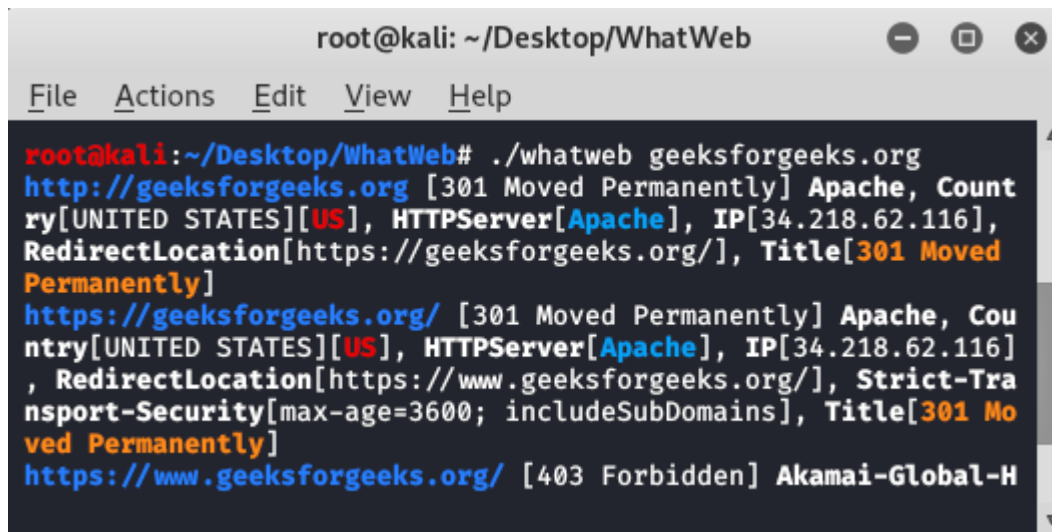
- Identifier rapidement les technologies utilisées par les sites web sur le réseau cible.
- Repérer d'éventuelles vulnérabilités associées aux technologies détectées.
- Automatiser la collecte d'informations sans effectuer de recherches manuelles.

Exemple d'utilisation :

```
whatweb -v https://example.com
```

Ce scan retourne les technologies utilisées par le site <https://example.com> avec un niveau de détail élevé.

Captures d'écran :



```
root@kali: ~/Desktop/WhatWeb
File Actions Edit View Help
root@kali:~/Desktop/WhatWeb# ./whatweb geeksforgeeks.org
http://geeksforgeeks.org [301 Moved Permanently] Apache, Count
ry[UNITED STATES][US], HTTPServer[Apache], IP[34.218.62.116],
RedirectLocation[https://geeksforgeeks.org/], Title[301 Moved
Permanently]
https://geeksforgeeks.org/ [301 Moved Permanently] Apache, Cou
ntry[UNITED STATES][US], HTTPServer[Apache], IP[34.218.62.116]
, RedirectLocation[https://www.geeksforgeeks.org/], Strict-Tra
nsport-Security[max-age=3600; includeSubDomains], Title[301 Mo
ved Permanently]
https://www.geeksforgeeks.org/ [403 Forbidden] Akamai-Global-H
```

Outil : W3af

Description de l'outil :

W3af (Web Application Attack and Audit Framework) est un framework avancé permettant de tester la sécurité des applications web. Il est conçu pour détecter et exploiter des vulnérabilités comme :

- **Injections SQL**
- **Cross-Site Scripting (XSS)**
- **Inclusions de fichiers (LFI/RFI)**
- **Répertoires et fichiers sensibles exposés**

Pourquoi on l'a utilisé :

Nous avons utilisé W3af pour :

- Analyser en profondeur la sécurité des applications web du réseau cible.
- Identifier et valider la présence de vulnérabilités exploitables.
- Automatiser les tests de pénétration sur des sites web.

Exemple d'utilisation :

w3af_console

w3af>>> target set target http://example.com

w3af>>> plugins audit sql_injection, xss

w3af>>> start

Ce scan analyse <http://example.com> à la recherche d'injections SQL et de failles XSS.

Captures d'écran :

```

root@kali: ~/w3af
File Edit View Search Terminal Help
w3af/plugins>>> audit all
w3af/plugins>>> back
w3af>>> start
Enabling format_string's dependency error_500
Enabling redos's dependency server_header
Enabling dav's dependency allowed_methods
Enabling frontpage's dependency frontpage_version
The server header for the remote web server is: "Apache/2.2.8 (Ubuntu) DAV/2".Th
is information was found in the request with id 36.
The x-powered-by header for the target HTTP server is "PHP/5.2.4-2ubuntu5.10".Th
is information was found in the request with id 37.
The web server at "http://192.168.145.128/mutillidae/" is vulnerable to Cross Si
te Tracing.This vulnerability was found in the request with id 44.
The web server at "http://192.168.145.128/mutillidae/" is vulnerable to Cross Si
te Tracing.This vulnerability was found in the request with id 44.
Found 1 URLs and 1 different injections points.
The URL list is:
- http://192.168.145.128/mutillidae/
The list of fuzzable requests is:
- Method: GET | http://192.168.145.128/mutillidae/
Scan finished in 5 seconds.
Stopping the core...
w3af>>> target
w3af/config:target>>> set target www.acuart.com

```

Outil :Wfuzz

Description de l'outil :

Wfuzz est un outil de fuzzing permettant de tester des entrées d'une application web en injectant des valeurs dynamiques. Il est souvent utilisé pour :

- **Bruteforcer des répertoires et fichiers cachés.**
- **Tester des paramètres GET/POST à la recherche de vulnérabilités.**
- **Détecter des pages d'administration accessibles.**

Pourquoi on l'a utilisé :

Nous avons utilisé Wfuzz pour :

- Trouver des répertoires ou fichiers cachés sur les serveurs web.
- Identifier des failles de sécurité basées sur des réponses HTTP anormales.
- Tester la robustesse des applications web face à des attaques de fuzzing.

Exemple d'utilisation :

```
wfuzz -c -z file,/usr/share/wordlists/dirb/common.txt --hc 404  
http://example.com/FUZZ
```

Ce scan tente d'identifier des répertoires et fichiers accessibles sur <http://example.com> en excluant les réponses 404.

Captures d'écran :

```
(kali@kali)-[~]
$ date +"%T.%3N" ; wfuzz -c -z file,simple-users.txt -d "username=FUZZ&password=oleksiyfb81" -u http://dyploma_chalyi_fb-81/signin.php --hc 200,404 ; date +"%T.%3N"
05:51:13.025
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://dyploma_chalyi_fb-81/signin.php
Total requests: 41

=====
ID           Response    Lines    Word      Chars      Payload
=====
000000041:   302          32 L     97 W      1088 Ch    "oleksiy"

Total time: 0
Processed Requests: 41
Filtered Requests: 40
Requests/sec.: 0

05:51:13.926
```

Outil : IA CMS Detector

Description de l'outil :

IA CMS Detector est un outil basé sur l'intelligence artificielle qui permet de détecter avec précision le CMS utilisé par un site web. Il analyse le code source, les fichiers présents, les requêtes HTTP et leurs signatures numériques pour identifier la technologie sous-jacente.

Cet outil peut reconnaître des plateformes comme :

- WordPress

- Joomla
- Drupal
- Magento

Pourquoi on l'a utilisé :

Nous avons utilisé IA CMS Detector pour :

- Déterminer avec précision les technologies web utilisées sur les sites cibles.
- Identifier d'éventuelles vulnérabilités spécifiques à chaque CMS.
- Comparer les résultats avec ceux d'autres outils de reconnaissance web.

Exemple d'utilisation :

[ia-cms-detector https://example.com](https://example.com)

Ce scan retourne le CMS et les technologies utilisées par le site web cible.

Scan de vulnérabilités Web

Nikto – Scanner Web pour la Détection des Vulnérabilités

Description Nikto

Nikto est un scanner de vulnérabilités web open-source qui permet d'identifier des failles de sécurité dans les serveurs web. Il analyse rapidement un site en testant plus de 6700 vulnérabilités connues, telles que les fichiers et répertoires exposés, les mauvaises configurations de serveurs, les failles XSS, et bien plus encore.

Utilisé par les pentesters, administrateurs système et chercheurs en cybersécurité, Nikto est un outil essentiel pour l'audit de la sécurité des applications web.

Fonctionnalités principales

- Scan rapide et approfondi des serveurs web à la recherche de vulnérabilités connues.
- Détection des fichiers et répertoires sensibles laissés accessibles par erreur.
- Identification des versions des serveurs web et des technologies utilisées.
- Test des certificats SSL/TLS pour détecter les mauvaises configurations.
- Support des proxys pour anonymiser les requêtes et éviter la détection.
- Automatisation possible via des scripts pour des audits en profondeur.

Exemple d'utilisation de Nikto

- Scanner un site web simple

nikto -h http://example.com

- Analyser un site avec HTTPS

nikto -h https://example.com

- Spécifier un port à scanner

nikto -h example.com -p 8080

- Utiliser un proxy pour masquer l'origine du scan

nikto -h example.com -useproxy http://127.0.0.1:8080

- Sauvegarder les résultats dans un fichier

nikto -h example.com -o rapport_scan.txt

- Scanner en mode rapide et éviter la détection par IDS

nikto -h example.com -Tuning 2

Pourquoi utiliser Nikto ?

- Analyse rapide des serveurs web pour détecter les erreurs de configuration.
- Vérification des fichiers sensibles laissés accessibles par erreur.
- Facile à utiliser et ne nécessite aucune configuration complexe.
- Intégration possible avec d'autres outils comme Metasploit pour des tests avancés.
- Outil incontournable en pentesting et audits de sécurité web.

Nikto vs Autres Scanners de Vulnérabilités Web

Outil	Type de Scan	Détection des vulnérabilités	Support SSL/TLS	Anonymisation via proxy

Nikto	Web	Oui (6700+ failles connues)	Oui	Oui
Burp Suite	Web	Oui (avec tests manuels)	Oui	Oui
OWASP ZAP	Web	Oui	Oui	Oui
Wapiti	Web	Oui (focus sur injections SQL, XSS, LFI, etc.)	Oui	Non

Nikto est un outil puissant et rapide pour identifier les vulnérabilités des serveurs web et améliorer leur sécurité.

SSL Check – Vérification et Analyse des Certificats SSL/TLS

Description SSL Check ?

SSL Check est un outil permettant d'analyser la configuration SSL/TLS d'un serveur web et de détecter les erreurs de configuration, les certificats expirés ou non valides, ainsi que les vulnérabilités liées aux protocoles et aux algorithmes de chiffrement.

Cet outil est particulièrement utile pour les administrateurs système, les pentesters et les experts en cybersécurité afin d'assurer la sécurisation des communications sur un site web.

Fonctionnalités principales

- Vérification de la validité du certificat SSL (date d'expiration, autorité de certification).
- Détection des vulnérabilités SSL/TLS connues (BEAST, POODLE, Heartbleed, ROBOT, etc.).
- Analyse des protocoles SSL/TLS pris en charge (SSL 3.0, TLS 1.2, TLS 1.3...).
- Vérification des suites de chiffrement utilisées (RSA, AES, ChaCha20, etc.).
- Test de compatibilité avec les navigateurs modernes et anciens.
- Possibilité de scanner des ports spécifiques pour identifier les services exposés.

Exemple d'utilisation de SSL Check

- Vérifier le certificat SSL d'un site web

`ssl-check example.com`

- Analyser un site avec un port spécifique (ex. : 443)

`ssl-check -h example.com -p 443`

- Vérifier les protocoles SSL/TLS supportés

`ssl-check -h example.com --tls-check`

- Détecter les attaques connues comme POODLE ou BEAST

`ssl-check -h example.com --vuln-check`

- Obtenir un rapport détaillé sur la configuration SSL/TLS

`ssl-check -h example.com -v --report ssl_report.txt`

Pourquoi utiliser SSL Check ?

- Assure la bonne configuration des certificats SSL pour éviter les erreurs.
- Détecte les vulnérabilités liées aux protocoles et algorithmes de chiffrement.
- Outil rapide et léger, facile à intégrer dans un pipeline de sécurité.

- Permet d'identifier les mauvaises configurations et d'optimiser la sécurité.
- Indispensable pour les audits de cybersécurité et la protection des communications web.

SSL Check vs Autres Outils d'Analyse SSL/TLS

Outil	Type de Scan	Détection des vulnérabilités	Support des protocoles	Génération de rapport
SSL Check	SSL/TLS	Oui	Oui	Oui
SSL Labs (Qualys)	SSL/TLS	Oui	Oui	Oui (via une interface web)
TestSSL.sh	SSL/TLS	Oui	Oui	Oui
OpenSSL	SSL/TLS	Partiel (manuel)	Oui	Non

SSL Check est un outil efficace pour tester la configuration SSL/TLS d'un serveur et garantir la sécurité des échanges de données.

OWASP ZAP – Scanner de Sécurité pour Applications Web

Description OWASP ZAP ?

OWASP ZAP (Zed Attack Proxy) est un scanner de vulnérabilités web open-source développé par l'OWASP. Il permet d'analyser et de tester les applications web pour identifier les failles de sécurité comme les injections SQL, XSS, CSRF, SSRF, LFI/RFI, et bien plus encore.

C'est un outil essentiel pour les pentesters, développeurs et administrateurs, car il facilite la détection des vulnérabilités et automatise les tests de sécurité web.

Fonctionnalités principales

- Scan automatique des applications web pour détecter les vulnérabilités.
- Mode proxy interactif pour analyser et modifier le trafic HTTP/HTTPS.
- Attaques ciblées et tests de pénétration manuels pour une analyse approfondie.
- Fuzzing des champs d'entrée pour détecter les vulnérabilités d'injection.
- Support des API REST et SOAP pour tester les applications modernes.
- Intégration avec CI/CD et DevSecOps pour automatiser la sécurité.

Exemple d'utilisation de OWASP ZAP

- Lancer un scan automatique d'un site web

```
zap-cli quick-scan -u http://example.com
```

- Démarrer OWASP ZAP en mode proxy pour intercepter les requêtes

```
zap.sh -daemon -port 8080
```

- Exécuter un scan actif sur une application

```
zap-cli active-scan -u http://example.com
```

- Fuzzer une entrée utilisateur avec OWASP ZAP

```
zap-cli fuzz -u http://example.com/login -p username -w wordlist.txt
```

- Générer un rapport détaillé des vulnérabilités détectées

```
zap-cli report -o rapport_zap.html -f html
```

Pourquoi utiliser OWASP ZAP ?

- Facile à utiliser, même pour les débutants en cybersécurité.
- Scan automatique puissant pour détecter les vulnérabilités les plus courantes.
- Mode proxy avancé pour inspecter et modifier le trafic HTTP/HTTPS.
- Totalement open-source et extensible avec des plugins.
- Compatible avec CI/CD pour des tests de sécurité automatisés.

OWASP ZAP vs Autres Scanners de Vulnérabilités Web

Outil	Type de Scan	Détection des vulnérabilités	Mode Proxy	Automatisation CI/CD
OWASP ZAP	Web	Oui (XSS, SQLi, CSRF, LFI...)	Oui	Oui
Burp Suite	Web	Oui (plus avancé en version Pro)	Oui	Oui (en version Pro)

Nikto	Web	Oui (scan rapide des serveurs)	Non	Non
Wapiti	Web	Oui (injections, XSS, LFI, etc.)	Non	Partiel

OWASP ZAP est un outil incontournable pour tester la sécurité des applications web et identifier les vulnérabilités avant qu'elles ne soient exploitées.

Burp Suite – Outil de Pentesting Web Complet

Description Burp Suite ?

Burp Suite est un outil de test d'intrusion (pentesting) web développé par PortSwigger. Il permet d'analyser, manipuler et tester la sécurité des applications web en interceptant et en modifiant le trafic HTTP/HTTPS.

Très utilisé par les pentesters, les chercheurs en sécurité et les développeurs, Burp Suite est une référence pour détecter et exploiter des vulnérabilités comme les injections SQL, XSS, CSRF, SSRF, LFI/RFI, et bien plus encore.

Fonctionnalités principales

- Proxy HTTP/HTTPS interactif pour intercepter et modifier le trafic.
- Scanner de vulnérabilités automatique (version Pro)
- Repeater pour rejouer et modifier des requêtes HTTP.
- Intruder pour tester les attaques par force brute et fuzzing
- Comparer et analyser les requêtes/réponses avec Diff
- Extensions et automatisation via l'API Burp.
- Support des API REST, SOAP et GraphQL pour tester les applications modernes.

Exemple d'utilisation de Burp Suite

- Configurer Burp Suite comme proxy dans le navigateur
 1. Ouvrir Burp Suite et aller dans "Proxy" > "Options".
 2. Ajouter un proxy sur 127.0.0.1:8080.
 3. Configurer le navigateur pour utiliser ce proxy.
 4. Intercepter le trafic et analyser les requêtes.
- Scanner une application web (version Pro)
 1. Aller dans "Target" > "Site Map".
 2. Clic droit sur une URL, puis "Activer le scan".
 3. Laisser Burp détecter les vulnérabilités.
- Utiliser Intruder pour un test de force brute sur un formulaire de connexion
 1. Aller dans "Intruder" > "Positions".
 2. Sélectionner le champ "username" ou "password".
 3. Charger une wordlist et lancer l'attaque.
- Rejouer une requête avec Repeater
 1. Sélectionner une requête dans "HTTP history".
 2. L'envoyer dans "Repeater" et modifier ses paramètres.

3. Observer la réponse du serveur pour analyser les vulnérabilités.

- Fuzzer des paramètres pour détecter des injections

1. Aller dans "Intruder" > "Payloads".

2. Charger une liste de payloads XSS ou SQLi.

3. Lancer l'attaque et analyser les réponses.

Pourquoi utiliser Burp Suite ?

- Outil complet pour l'audit de sécurité des applications web.
- Mode proxy puissant pour capturer et modifier les requêtes HTTP/HTTPS.
- Scanner de vulnérabilités efficace (version Pro).
- Fuzzing avancé pour détecter les failles XSS, SQLi, LFI, etc..
- Extensible via des plugins pour des analyses plus poussées.
- Compatible avec DevSecOps et intégration CI/CD (version Pro).

Burp Suite vs Autres Scanners de Sécurité Web

Outil	Type de Scan	Détection des vulnérabilités	Proxy Intercept	Automatisation CI/CD
Burp Suite	Web	Oui (XSS, SQLi, CSRF, LFI, etc.)	Oui	Oui (version Pro)
OWASP ZAP	Web	Oui (XSS, SQLi, CSRF, LFI, etc.)	Oui	Oui
Nikto	Web	Oui (serveurs web)	Non	Non

Wapiti	Web	Oui (scan automatique)	Non	Partiel
--------	-----	------------------------	-----	---------

Burp Suite est un outil incontournable pour tester la sécurité des applications web et identifier les vulnérabilités avant qu'elles ne soient exploitées.

SSLyze – Analyse Avancée des Configurations SSL/TLS

Description SSLyze ?

SSLyze est un outil d'analyse de sécurité SSL/TLS permettant d'évaluer la configuration des serveurs web en matière de certificats SSL, protocoles, algorithmes de chiffrement et vulnérabilités connues.

Développé en Python, SSLyze est largement utilisé par les administrateurs système, les pentesters et les chercheurs en cybersécurité pour identifier les failles et améliorer la sécurité des connexions HTTPS.

Fonctionnalités principales

- Analyse des certificats SSL/TLS (validité, expiration, autorité de certification).
- Détection des protocoles pris en charge (SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.2, TLS 1.3).
- Vérification des algorithmes de chiffrement et des suites TLS utilisées.
- Détection des vulnérabilités connues (BEAST, POODLE, Heartbleed, ROBOT, etc.).
- Support du scan des serveurs SMTP, FTPS, et autres services SSL/TLS.

- Exécution rapide avec support du multithreading.
- Export des résultats en JSON ou XML pour une analyse automatisée.

Exemple d'utilisation de SSLyze

- Scanner un site web avec SSLyze

```
sslyze --regular example.com
```

- Vérifier les protocoles TLS supportés

```
sslyze --tlsv1_0 --tlsv1_1 --tlsv1_2 --tlsv1_3 example.com
```

- Analyser les suites de chiffrement acceptées

```
sslyze --cipher-suites example.com
```

- Vérifier si le serveur est vulnérable à BEAST ou POODLE

```
sslyze --compression --heartbleed --fallback example.com
```

- Exporter le rapport d'analyse en JSON

```
sslyze --json_out=rapport_sslyze.json example.com
```

Pourquoi utiliser SSLyze ?

- Analyse complète et rapide des configurations SSL/TLS.
- Détection des protocoles et suites de chiffrement non sécurisés.
- Outil open-source facile à utiliser et intégrable dans un pipeline CI/CD.
- Essentiel pour les audits de cybersécurité et la conformité aux bonnes pratiques SSL/TLS.
- Compatible avec les scans des serveurs HTTPS, SMTP, IMAP, FTPS, etc..

SSLyze vs Autres Outils d'Analyse SSL/TLS

Outil	Type de Scan	Détection des vulnérabilités	Support des protocoles	Génération de rapports
SSLyze	SSL/TLS	Oui	Oui	Oui (JSON, XML)
SSL Labs (Qualys)	SSL/TLS	Oui	Oui	Oui (via une interface web)
TestSSL.sh	SSL/TLS	Oui	Oui	Oui
OpenSSL	SSL/TLS	Partiel (manuel)	Oui	Non

SSLyze est un outil puissant pour auditer la sécurité des configurations SSL/TLS et détecter les failles avant qu'elles ne soient exploitées.

Tests d'injection et d'exploitation Web

SQLMap – Outil d'Injection SQL Automatisé

Description SQLMap ?

SQLMap est un outil open-source utilisé pour détecter et exploiter automatiquement les failles d'injection SQL sur des applications web. Il est capable d'identifier, tester et exploiter plusieurs types d'injections SQL, permettant ainsi aux pentesters et analystes en cybersécurité de détecter les vulnérabilités dans les bases de données d'une cible.

SQLMap automatise entièrement le processus d'exploitation, depuis la détection de la faille jusqu'à l'exfiltration des données, le dump de bases de données ou même l'exécution de commandes système sur les serveurs vulnérables.

Fonctionnalités principales

- Détection automatique des vulnérabilités SQL sur des sites web.
- Supporte plusieurs types d'injection SQL, notamment :
 - Boolean-based Blind SQL Injection
 - Time-based Blind SQL Injection
 - Error-based SQL Injection
 - Union-based SQL Injection
 - Stacked Queries & Out-of-band Injection
- Exfiltration de données (bases, tables, colonnes, utilisateurs...).
- Possibilité d'exécuter des commandes sur un serveur vulnérable.
- Supporte plusieurs bases de données : MySQL, PostgreSQL, MSSQL, Oracle, SQLite, etc.
- Bypass des protections WAF et IDS grâce à des techniques avancées d'évasion.

Exemple d'utilisation de SQLMap

- Tester si un paramètre est vulnérable à une injection SQL

```
sqlmap -u "http://example.com/index.php?id=1" --batch --dbs
```

- Lister les bases de données d'un serveur vulnérable

```
sqlmap -u "http://example.com/index.php?id=1" --dbs
```

- Récupérer les tables d'une base spécifique

```
sqlmap -u "http://example.com/index.php?id=1" -D database_name --tables
```

- Extraire les colonnes d'une table cible

```
sqlmap -u "http://example.com/index.php?id=1" -D database_name -T users --columns
```

- Dumper les données d'une table (ex. : identifiants utilisateurs)

```
sqlmap -u "http://example.com/index.php?id=1" -D database_name -T users --dump
```

- Exécuter une commande système sur le serveur

```
sqlmap -u "http://example.com/index.php?id=1" --os-shell
```

Pourquoi utiliser SQLMap ?

- Automatise entièrement l'exploitation des injections SQL.
- Puissant et rapide, adapté aux pentesters et red teams.
- Compatible avec la majorité des bases de données SQL.
- Peut contourner des protections comme les WAF/IDS.
- Indispensable pour les audits de sécurité des applications web.

SQLMap vs Autres Outils d'Exploitation SQL

Outil	Type d'exploitation	Automatisation	Bases supportées	Utilisation principale

SQLMap	Injection SQL	Automatisé	MySQL, PostgreSQL, MSSQL, Oracle...	Pentesting et exploitation des failles SQL
Havij	Injection SQL	Semi-automatisé	MySQL, MSSQL, PostgreSQL	Test d'injection avec interface graphique
JSQL Injection	Injection SQL	Automatisé	MySQL, PostgreSQL, Oracle	Tests d'injection en Java avec interface graphique

SQLMap est l'outil incontournable pour les pentesters souhaitant tester et exploiter les vulnérabilités SQL d'une application web.

Gobuster – Scanner de Contenu & de Sous-Domains Rapide

Description Gobuster ?

Gobuster est un outil open-source, rapide et efficace, conçu pour bruter des répertoires, fichiers cachés et sous-domaines sur des serveurs web. Il est écrit en Go, ce qui le rend extrêmement rapide et léger comparé à d'autres outils de reconnaissance. Il est souvent utilisé en pentesting et en audit de sécurité pour détecter des endpoints cachés, des fichiers sensibles et des sous-domaines non documentés.

Fonctionnalités principales

- Bruteforce de répertoires et de fichiers sur un site web
- Détection de sous-domaines cachés

- Exploration de fichiers et extensions spécifiques (ex. : .php, .txt, .bak)
- Utilisation de wordlists personnalisées
- Multithreading pour une exécution rapide
- Compatible avec les protocoles HTTP, HTTPS et DNS
- Option pour contourner les certificats SSL invalides

Exemple d'utilisation de Gobuster

- Scanner des répertoires cachés sur un site web

```
gobuster dir -u http://example.com -w
/usr/share/wordlists/dirb/common.txt
```

- Rechercher des fichiers spécifiques (ex. : .php, .html, .bak)

```
gobuster dir -u http://example.com -w
/usr/share/wordlists/dirb/common.txt -x php,html,bak
```

- Scanner des sous-domaines d'un domaine cible

```
gobuster dns -d example.com -w
/usr/share/wordlists/subdomains-top1million-5000.txt
```

- Contourner un certificat SSL invalid

```
gobuster dir -u https://example.com -w
/usr/share/wordlists/dirb/common.txt -k
```

- Augmenter la vitesse d'exécution avec plus de threads

```
gobuster dir -u http://example.com -w
/usr/share/wordlists/dirb/common.txt -t 50
```

Pourquoi utiliser Gobuster ?

- Plus rapide que des outils similaires, grâce à Go.
- Idéal pour découvrir des répertoires et fichiers cachés sur un serveur.
- Indispensable pour la reconnaissance et la cartographie d'une application web.

- Permet aussi la découverte de sous-domaines non listés.

Gobuster vs Autres Outils de Bruteforce Web

Outil	Type de Scan	Langage	Rapidité	Utilisation principale
Gobuster	Fichiers, répertoires, sous-domaines	Go		Pentesting web rapide
Dirb	Répertoires & fichiers	C		Scan classique mais plus lent
FFUF	Fuzzing web avancé	Go		Tests de fuzzing et bruteforce de paramètres

Gobuster est l'un des meilleurs outils pour trouver rapidement des fichiers cachés et des sous-domaines lors d'un pentest web.

LFI Finder – Détecteur Automatisé de Failles LFI

Description LFI Finder ?

LFI Finder est un outil open-source conçu pour détecter automatiquement les vulnérabilités Local File Inclusion (LFI) sur des sites web. Il parcourt les URL d'une cible et tente d'identifier des points

d'inclusion de fichiers locaux, une faille courante permettant d'accéder à des fichiers sensibles du serveur, tels que :

- `/etc/passwd` (sous Linux)
- `C:\Windows\System32\drivers\etc\hosts` (sous Windows)
- Les fichiers de configuration des applications web

Utilisé par les pentesters et les experts en cybersécurité, LFI Finder facilite l'identification de ces vulnérabilités en automatisant le processus de détection.

Fonctionnalités principales

- Scan rapide et automatisé des sites web pour détecter des vulnérabilités LFI.
- Détection des paramètres vulnérables aux attaques d'inclusion de fichiers.
- Support des techniques de contournement (encodage, bypass, etc.).
- Test d'exploitation sur plusieurs endpoints simultanément.
- Facile à intégrer dans un workflow de pentest.

Exemple d'utilisation de LFI Finder

- Scanner un site pour détecter des vulnérabilités LFI

```
python3 lfi_finder.py -u "http://example.com/index.php?page="
```

- Tester plusieurs URL en fournissant une liste de cibles

```
python3 lfi_finder.py -l urls.txt
```

- Essayer différentes méthodes de contournement (encodage, chemins alternatifs, etc.)

```
python3 lfi_finder.py -u "http://example.com/index.php?page=" --bypass
```

- Scanner un site en mode agressif

```
python3 lfi_finder.py -u "http://example.com/index.php?page="
--aggressive
```

Pourquoi utiliser LFI Finder ?

- Automatise la détection des failles LFI, sans besoin de tests manuels fastidieux.
- Gain de temps considérable pour les pentesters et les auditeurs de sécurité.
- Détecte les vulnérabilités courantes et teste les bypass possibles.
- Compatible avec d'autres outils de test web comme Burp Suite, SQLMap, Wfuzz.

LFI Finder vs Autres Outils de Détection de Failles LFI

Outil	Type de Scan	Automatisation	Bypass intégrés	Utilisation principale
LFI Finder	LFI uniquement	Oui	Oui	Détection rapide des vulnérabilités LFI
Wfuzz	Fuzzing web général	Oui	Non	Recherche de vulnérabilités variées (LFI, SQLi, XSS...)
Burp Suite	Analyse web complète	Partielle	Oui (avec plugins)	Test manuel et semi-automatisé des applications web

LFI Finder est un outil indispensable pour identifier rapidement les vulnérabilités LFI et les fichiers sensibles accessibles sur un serveur web.

XSRF Probe – Scanner Automatisé de Failles CSRF

Description XSRF Probe

XSRF Probe est un outil open-source conçu pour détecter automatiquement les vulnérabilités Cross-Site Request Forgery (CSRF) dans les applications web. Il analyse les formulaires et les requêtes HTTP d'un site cible pour identifier les endpoints potentiellement exploitables par une attaque CSRF.

Les failles CSRF permettent à un attaquant de forcer un utilisateur authentifié à exécuter des actions à son insu, comme changer un mot de passe, modifier des paramètres ou effectuer des transactions frauduleuses.

XSRF Probe est utilisé par les pentesters et les chercheurs en cybersécurité pour tester la sécurité des protections CSRF dans les applications web modernes.

Fonctionnalités principales

- Analyse automatique des protections CSRF sur un site web.
- Détection des formulaires vulnérables sans jeton CSRF valide.
- Génération de POCs (Proof of Concept) pour tester les failles détectées.
- Support de l'analyse des requêtes GET et POST.
- Facilement intégrable dans un workflow de pentesting web.

Exemple d'utilisation de XSRF Probe

- Scanner un site web à la recherche de failles CSRF

`xsrprobe -u http://example.com`

- Analyser une URL spécifique

```
xsrprobe -u http://example.com/admin/change-password
```

- Générer un exploit CSRF automatiquement

```
xsrprobe -u http://example.com -e
```

- Augmenter le niveau de détail du scan

```
xsrprobe -u http://example.com -v
```

- Tester uniquement les requêtes POST

```
xsrprobe -u http://example.com --only-post
```

Pourquoi utiliser XSRF Probe ?

- Automatiser la détection des vulnérabilités CSRF sur une application web.
- Génère des POCs exploitables pour tester la faille facilement.
- Indispensable pour les audits de sécurité des sites web.
- Facile à utiliser, même pour les débutants en cybersécurité.

XSRF Probe vs Autres Outils de Détection CSRF

Outil	Type de Scan	Automatisation	Génération de POC	Utilisation principale
XSRF Probe	CSRF uniquement	Oui	Oui	Détection et exploitation des failles CSRF
Burp Suite	Analyse web complète	Partielle	Oui (avec plugins)	Tests manuels et semi-automatisés
OWASP ZAP	Analyse de vulnérabilités web	Partielle	Non	Scan général de sécurité web

XSRF Probe est un outil puissant et rapide pour identifier les failles CSRF et tester la sécurité des formulaires et requêtes HTTP.

Tests d'exploitabilité applicative

CSRF Tester – Outil de Détection et d'Exploitation des Failles CSRF

Description CSRF Tester ?

CSRF Tester est un outil open-source conçu pour identifier et exploiter automatiquement les vulnérabilités Cross-Site Request Forgery (CSRF) dans les applications web. Il permet d'analyser les formulaires et requêtes HTTP pour détecter l'absence de protections contre les attaques CSRF.

Une attaque CSRF permet à un attaquant de forcer une victime authentifiée à exécuter des actions malveillantes à son insu, comme changer un mot de passe, transférer de l'argent ou modifier des paramètres critiques.

CSRF Tester est largement utilisé en pentesting et en audits de sécurité pour vérifier si une application implémente correctement des protections telles que les jetons CSRF et les en-têtes de validation.

Fonctionnalités principales

- Analyse automatique des formulaires et requêtes HTTP à la recherche de failles CSRF.
- Détection des endpoints vulnérables où un attaquant pourrait envoyer des requêtes malveillantes.
- Génération automatique de POC (Proof of Concept) exploitables.
- Support des requêtes GET et POST pour tester divers scénarios d'attaque.
- Interface simple et facile à utiliser pour pentesters et chercheurs en cybersécurité.

Exemple d'utilisation de CSRF Tester

- Scanner une URL pour détecter une faille CSRF

```
csrf-tester -u http://example.com
```

- Analyser un formulaire spécifique

```
csrf-tester -u http://example.com/admin/change-password
```

- Générer un exploit CSRF automatiquement

```
csrf-tester -u http://example.com -e
```

- Exécuter une analyse détaillée avec mode verbeux

```
csrf-tester -u http://example.com -v
```

- Tester uniquement les requêtes POST

```
csrf-tester -u http://example.com --only-post
```

Pourquoi utiliser CSRF Tester ?

- Automatise la détection des failles CSRF, évitant les tests manuels chronophages.
- Génère des preuves d'exploitation (POC) permettant de tester rapidement la faille.
- Indispensable pour les pentesters et auditeurs en cybersécurité.
- Facile à utiliser, même pour les débutants en tests de sécurité web.

CSRF Tester vs Autres Outils de Détection CSRF

Outil	Type de Scan	Automatisation	Génération de POC	Utilisation principale
CSRF Tester	CSRF uniquement	Oui	Oui	Détection et exploitation des failles CSRF

XSRF Probe	CSRF uniquement	Oui	Oui	Scan rapide et ciblé des protections CSRF
Burp Suite	Analyse web complète	Partielle	Oui (avec plugins)	Tests manuels et semi-automatisés
OWASP ZAP	Analyse de vulnérabilités web	Partielle	Non	Scan de sécurité web général

CSRF Tester est un outil efficace et simple pour identifier les vulnérabilités CSRF et tester la sécurité des applications web contre ce type d'attaque.

The screenshot displays the Burp Suite interface with three main panels:

- Tasks:** Shows two active tasks:
 - 1. Live passive crawl from Proxy (all traffic): 36 items added to site map, 32 responses processed, 0 responses queued.
 - 2. Live audit from Proxy (all traffic): Audit checks - passive, 0 requests (0 errors).
- Issue activity:** A table listing detected issues:

#	Task	Time	Action	Issue type
9	2	10:30:58 29 Jun 2023	Issue found	1 Cross-domain Referer leakage
8	2	10:30:58 29 Jun 2023	Issue found	1 Email addresses disclosed
7	2	10:30:51 29 Jun 2023	Issue found	1 Cacheable HTTPS response
6	2	10:30:51 29 Jun 2023	Issue found	1 Password field with autocomplete enabled
5	2	10:28:01 29 Jun 2023	Issue found	1 Cacheable HTTPS response
4	2	10:28:01 29 Jun 2023	Issue found	1 Cacheable HTTPS response
3	2	10:28:01 29 Jun 2023	Issue found	1 Cacheable HTTPS response
2	2	10:28:01 29 Jun 2023	Issue found	1 Cacheable HTTPS response
1	2	10:28:01 29 Jun 2023	Issue found	1 Strict transport security not enforced
- Event log:** Shows a log entry at 10:27:24 29 Jun 2023, Type: Info, Source: Proxy, Message: Proxy service started on 127.0.0.1:8080.

CodeQL – Analyse Statique pour la Détection des Vulnérabilités

Description CodeQL ?

CodeQL est un moteur d'analyse statique développé par GitHub permettant d'identifier des vulnérabilités et des failles de sécurité dans le code source. Il transforme le code en base de données interrogeable via un langage de requête inspiré de SQL, facilitant ainsi la détection de patterns malveillants ou de mauvaises pratiques de développement.

Utilisé par les chercheurs en sécurité, les pentesters et les développeurs, CodeQL permet d'automatiser la recherche de failles de type SQL Injection, XSS, Buffer Overflow, et bien plus encore.

Fonctionnalités principales

- Analyse statique avancée des langages comme C, C++, Java, Python, JavaScript, Go, etc.
- Détection automatique des vulnérabilités connues et erreurs logiques.
- Possibilité d'écrire ses propres règles de détection via des requêtes CodeQL personnalisées.
- Intégration avec GitHub Actions et CI/CD pour automatiser la sécurité du code.
- Vérification des dépendances et des librairies tierces pour identifier les vulnérabilités connues.
- Facilement extensible grâce à une large base de requêtes open-source.

Exemple d'utilisation de CodeQL

- Initialiser une base de données CodeQL à partir d'un projet

```
codeql database create --language=javascript  
--source-root=./mon_projet --database=mon_projet_db
```

- Analyser le code avec une requête CodeQL prédéfinie

```
codeql query run --database=mon_projet_db  
codeql/javascript-queries:sql-injection
```

- Lister toutes les vulnérabilités détectées

```
codeql database analyze mon_projet_db --format=csv  
--output=resultats.csv
```

- Écrire une requête personnalisée pour détecter des erreurs spécifiques

```
SELECT function, location FROM Code WHERE function.name = "eval"
```

- Automatiser CodeQL dans un pipeline CI/CD avec GitHub Actions

jobs:

security_scan:

runs-on: ubuntu-latest

steps:

- name: Checkout du code

uses: actions/checkout@v2

- name: Analyse de sécurité avec CodeQL

uses: github/codeql-action/init@v1

with:

languages: javascript, python

- name: Exécuter l'analyse CodeQL

uses: github/codeql-action/analyze@v1

Pourquoi utiliser CodeQL ?

- Détection avancée des failles de sécurité dès la phase de développement.
- Automatisation des analyses dans les pipelines DevSecOps.
- Personnalisation des règles de détection pour répondre aux besoins spécifiques d'un projet.
- Supporte plusieurs langages de programmation et s'intègre facilement avec GitHub.

- Utilisé par des entreprises et chercheurs en cybersécurité pour identifier des vulnérabilités critiques.

CodeQL vs Autres Outils d'Analyse Statique

Outil	Type d'Analyse	Langages Supportés	Automatisation CI/CD	Détection Personnalisée
CodeQL	Analyse statique avancée	C, C++, Java, Python, JavaScript, Go...	Oui (GitHub Actions, CI/CD)	Oui
SonarQube	Analyse statique et qualité de code	Multi-langages	Oui	Partiellement
Semgrep	Analyse statique	Python, JavaScript, Go, etc.	Oui	Oui (règles personnalisées)
Bandit	Analyse des vulnérabilités Python	Python uniquement	Oui	Non

CodeQL est un outil puissant et flexible pour analyser le code source et identifier les failles de sécurité de manière automatisée.

JavaConverter.java

```
public static Object deserialize (InputStream is)
    throws IOException {
    ObjectInputStream ois = new ObjectInputStream(is);
    return ois.readObject();
}
```

UnsafeDeserialization.q1

```
from PathNode source, PathNode sink
where flowPath(source, sink)
select sink.getNode().(UnsafeDeserializationSink)
    .getMethodAccess(),
    source, sink, "Unsafe deserialization of $@",
    source.getNode(), "user input"
```

QL Query Results

alerts ▾

> ☰ Unsafe deserialization of [user input](#).

▾ ☰ Unsafe deserialization of [user input](#).

▾ Path

```
1 getContent\(...\) : InputStream
2 getContentAsStream\(...\) : InputStream
3 toBufferedInputStream\(...\) : InputStream
4 getInputStream\(...\) : InputStream
5 is : InputStream
6 ois
```

> Path

> ☰ Unsafe deserialization of [user input](#).

Mode avancé & automatisation

Google Dork

Description :

Le Google Dorking (ou Google Hacking) est une technique de recherche avancée qui exploite les puissantes fonctionnalités de Google pour extraire des informations précises qui ne sont généralement pas accessibles via une recherche classique. Cette méthode repose sur des opérateurs de recherche avancés permettant d'affiner les résultats et de cibler des données spécifiques.

Fonctionnalités principales

Les fonctionnalités principales de Google Dork sont :

- Recherche par Type de Fichier (filetype:) :

L'opérateur filetype: permet de rechercher des fichiers spécifiques en filtrant par type de fichier. Par exemple, si vous souhaitez trouver des fichiers PDF contenant un certain mot-clé, vous pouvez utiliser la syntaxe filetype:pdf mot-clé. Cela permet de se concentrer uniquement sur les fichiers d'un format particulier, comme des rapports, des présentations ou des bases de données.

- Recherche dans l'URL (inurl:) :

L'opérateur inurl: permet de rechercher des mots-clés dans l'URL d'une page web. Cela est utile pour trouver des pages dont l'adresse contient un terme précis, comme des pages administratives ou de connexion. Par exemple, inurl:admin vous permet de trouver toutes les pages dont l'URL contient "admin", ce qui peut être utile pour localiser des sections d'administration de sites web.

- Recherche dans le Titre de la Page (intitle:) :

L'opérateur intitle: recherche des mots-clés dans le titre d'une page web. Cette fonctionnalité est souvent utilisée pour trouver des pages qui ont un titre spécifique, comme des formulaires de connexion ou des pages contenant des informations importantes. Par exemple, intitle:login trouvera des pages ayant "login" dans leur titre.

Pourquoi utiliser Google Dork

Google Dork est une puissante technique permettant d'exploiter les opérateurs avancés de Google pour rechercher des informations spécifiques sur le web. Il est particulièrement utile dans des domaines comme la cybersécurité, où il permet de détecter des failles de sécurité, des fichiers mal protégés ou des informations sensibles exposées par erreur. Dans le cadre du renseignement en sources ouvertes (OSINT), il aide à collecter des données publiques sur des personnes ou des entreprises, facilitant ainsi l'analyse et la veille stratégique. Google Dork est également précieux pour l'optimisation du référencement (SEO), permettant de vérifier l'indexation correcte des pages d'un site ou de repérer du contenu dupliqué. Enfin, il permet d'effectuer des recherches avancées en affinant les résultats pour trouver précisément ce que l'on cherche, qu'il s'agisse de fichiers spécifiques ou d'informations précises. Cependant, son utilisation doit se faire de manière éthique et légale, en respectant les règles de confidentialité.

XSSStrike

Description

XSSStrike est un outil de test de pénétration spécialisé dans la détection, l'exploitation et la prévention des attaques XSS. Il est particulièrement efficace grâce à sa capacité à automatiser les tests d'injection et à utiliser une large gamme de techniques pour contourner les mécanismes de sécurité modernes comme les filtres d'entrée et les protections contre

les attaques XSS. Il utilise une approche intelligente pour détecter les vulnérabilités XSS et peut fonctionner sur une grande variété de sites web. XSSStrike est basé sur Python et offre une interface utilisateur simple, mais avec une puissance de détection avancée.

Fonctionnalités principales

Les fonctionnalités principales de XSSStrike sont :

- **Scanner XSS Intelligent** : XSSStrike utilise une méthode d'analyse avancée pour identifier les vulnérabilités XSS dans les applications web. Il explore de manière approfondie les paramètres d'entrée, les formulaires et les en-têtes HTTP afin de détecter des failles de sécurité potentielles liées aux attaques XSS.
- **Bypass des Filtres de Sécurité** : XSSStrike inclut des mécanismes permettant de contourner les protections classiques, telles que les filtres de caractères ou les systèmes de prévention des intrusions, augmentant ainsi la probabilité d'exploiter les vulnérabilités XSS même lorsque des filtres sont en place.
- **Interface Utilisateur Accessible** : XSSStrike offre une interface en ligne de commande pour les utilisateurs avancés, mais propose également une interface graphique simple et accessible pour faciliter les tests rapides, rendant l'outil utilisable aussi bien par des débutants que des professionnels de la sécurité

Pourquoi utiliser XSSStrike ?

- **Complet et efficace** : XSSStrike est un outil très complet pour détecter et exploiter les vulnérabilités XSS, offrant à la fois des méthodes simples et avancées pour contourner les protections de sécurité.
- **Automatisation des tests XSS** : XSSStrike permet d'automatiser la détection des failles XSS, ce qui peut grandement accélérer le processus de test de sécurité pour les applications web.
- **Précision des résultats** : Grâce à ses techniques intelligentes de reconnaissance et de fuzzing, XSSStrike est capable de repérer des vulnérabilités qui pourraient échapper à d'autres outils moins sophistiqués.

- **Open-source et gratuit** : XSSStrike est open-source et peut être utilisé gratuitement, ce qui le rend accessible à tous, des chercheurs en sécurité amateurs aux professionnels expérimentés.

- **Facilité d'utilisation** : Malgré sa puissance, l'outil reste relativement simple à utiliser, ce qui en fait une bonne option même pour ceux qui n'ont pas une expertise technique poussée.

Exemple:

Sécurité administrateur

Sujet : <https://fayzanjimi.com>

- Trouvé **1 compte administrateur** avec un mot de passe faible (brute force fonctionnel avec fichier rockyou.txt).
- **Criticité** : Accès administrateur compromis, possibilité de modifier la base de données sans restriction.
- **Remédiation** : Appliquer les recommandations de l'ANSSI : utiliser des mots de passe d'au moins **12 caractères** avec majuscules, minuscules, chiffres et caractères spéciaux.

Score : -100

OWASP – Security Logging and Monitoring Failures

Sujet : fayzanjimi.com

Weakness ID: 532

- **Criticité :** Logs contenant des données sensibles :
 - Prénom et nom des utilisateurs
 - Carte bancaire utilisée
 - Adresse e-mail privée
 - Pays de résidence
- **Recommandation :**
 - Enregistrer correctement les échecs de connexion et tentatives suspectes.
 - Encoder les logs pour éviter les injections.
 - Mettre en place un **plan de réponse aux incidents** (NIST 800-61r2).
 - Utiliser des outils open source comme **ELK (Elasticsearch, Logstash, Kibana)** pour surveiller les logs.

CWE-532 : Insertion de données sensibles dans des fichiers de logs (Insertion of Sensitive Information into Log File)

Score : -25

SSL/TLS : Certificat non valide ou non identifiable

CA : Fayzan Jimi CA

- **Cause :** Certificat **auto-signé**, pas émis par une autorité reconnue.
- **Criticité :**
 - Risque de compromission des échanges entre les utilisateurs et le serveur.
 - Problème de confiance avec les navigateurs.
- **Recommandation :** Obtenir un certificat SSL/TLS d'un **fournisseur reconnu** (ex : Let's Encrypt, DigiCert).

Score : -30

CVE : Vulnérabilités connues

Sujet : fayzanjimi.com

CVE-2025-1789 : Remote Code Execution (CMS utilisé obsolète)

- **Criticité :** 9.8/10
- Le site utilise **une ancienne version du CMS**, vulnérable à l'exécution de code à distance.
- Un attaquant peut téléverser un fichier malveillant et exécuter des commandes sur le serveur.

Recommandation :

- Mettre à jour le CMS immédiatement.
- Vérifier régulièrement les mises à jour de sécurité.

Score : -20

Général - Score final

1. **Faille OWASP** (Vulnérabilités dans le Top 10 OWASP) → **-25 points**
2. **Présence de CVE critique** → **-20 points**
3. **Problème de certificat SSL** → **-30 points**
4. **Mot de passe administrateur faible** → **-100 points**

Note finale

- **OWASP** : 75/100
- **CVE** : 80/100
- **Communication** : 70/100
- **Sécurité Administrateur** : 0/100

Grade attribué : C (site peu sécurisé avec failles majeures)